

Rapport d'audit de sécurité et plan de remédiation

Olivier HIMBLOT — Travail individuel de formation — 1er octobre 2026

Objectif et statut

Présenter une synthèse compréhensible sans avoir participé aux scans, puis préparer les mesures à mettre en œuvre à partir du J4. Ce rapport reprend la consolidation des trois sources et complète la priorisation avec C12, identifié au J3. Les éléments antérieurs sont issus des feuilles du dossier ; les huit captures ajoutées et le JSON Trivy disponible ont été examinés pour cette version.

Rapport et plan préparés ; remédiations non appliquées. Les validations après changement sont des critères attendus, pas des résultats acquis. Les actions restent conditionnées aux dépendances et investigations indiquées.

Traçabilité et portée des preuves

Trois niveaux de preuve sont distingués : **capture examinée, export JSON examiné et résultat consigné dans les feuilles antérieures**. Les versions locales, montages, droits et qualifications CVE repris ci-dessous sont documentés dans ces feuilles ; les huit captures ajoutées ne suffisent pas à les prouver individuellement. Aucun nouvel audit de la VM, aucune exploitation et aucune remédiation n'ont été exécutés pour rédiger ce document.

Les captures ont été enregistrées le 1er octobre, mais les rapports Greenbone affichent des scans du **30 septembre 2026**. Le scan A est terminé de **12:02 à 12:17, heure de Paris**, et le scan B de **12:13 à 12:29**. Les plages se chevauchent : il ne faut pas décrire les scans comme strictement successifs. Les libellés des tâches identifient le contexte A/B, sans prouver seuls tous les paramètres ni la réussite de l'authentification SSH.

Le scan B affiche « Results (200 of 387) » et le scan A « Results (3 of 33) », avec le filtre `apply_overrides=0 levels=chml min_qod=70 result_hosts_only=0`. Ces compteurs d'interface ne correspondent pas à un nombre de vulnérabilités uniques confirmées. La valeur de 2 122 dans l'onglet CVEs du scan B ne démontre pas 2 122 vulnérabilités exploitables.

Le JSON Trivy présent contient **48 associations pour Alpine et 108 pour le binaire File Browser**, soit **156 : 143 HIGH et 13 CRITICAL**. Il identifie Alpine 3.13.4 avec `E0SL=true`, 20 paquets Alpine et 53 composants Go. Le code retour 0 du premier scan signifie une exécution réussie avec les options employées ; il ne signifie pas une absence de vulnérabilité. Le second scan écrit au même chemin et filtre HIGH/CRITICAL : l'empreinte affichée pour le premier export ne doit pas être attribuée au fichier actuel sans nouveau calcul.

1. Système, périmètre et méthodes

Le système étudié est une VM Ubuntu 20.04.6 LTS, noyau 5.15.0-139-generic, exécutant Docker/containerd et File Browser 2.15.0. Le service applicatif est publié en HTTP sur le port hôte 8080 vers le port 80 du conteneur. SSH fournit l'administration sur le port 22. CUPS est actif, limité à localhost, sans rôle d'impression identifié.

Le cas fil rouge prévoit des documents publics, internes et partenaires. Les répertoires correspondants sont montés depuis `/srv/filebrowser` vers `/srv` en lecture-écriture. File Browser est observé avec UID/GID 0

dans le conteneur, qui n'est pas privilégié. La sensibilité des données appartient au contexte pédagogique ; aucune exfiltration ni accès croisé aux documents n'a été démontré.

Exposition établie : depuis la machine d'audit du laboratoire. L'accès Internet prévu dans le cas n'est pas prouvé. Les observations concernent l'état relevé ; les arrêts VM et conteneur ont été expliqués comme volontaires.

Méthode / outil	Périmètre et résultat exploitable	Limites
Greenbone/ OpenVAS J1	Scans A distant et B avec compte SSH gvm-audit ; liste de ports « All IANA assigned TCP » visible dans les captures ; couverture effective à contrôler ; écarts de paquets hôte et MAC SSH	Compte sans sudo ; pas d'inventaire exhaustif de l'image ; aucune couverture UDP revendiquée ; absence d'identification File Browser dans les exports
Lynis 2.6.2 J2	Audit local de la VM : 221 tests, 4 avertissements, 52 suggestions, indice 57 ; recommandations SSH, auditd, CUPS, noyau et Docker	Audit interne au conteneur non réalisé ; indice de durcissement non assimilable à un niveau de risque ; métadonnées/empreintes du second rapport à compléter
Docker et contrôles manuels	Image et digests, versions, services, écoutes, droits, UID du processus, montages, configuration SSH et journaux	Observations ponctuelles ; aucune exploitation ni validation générale après redémarrage
Trivy 0.74.0 J3	Image exacte exportée/transférée avec empreinte concordante ; 20 paquets Alpine et 53 composants Go ; analyse antérieure : 294 associations composant-vulnérabilité, dont 13 critiques ; export actuel filtré : 156 associations (143 HIGH et 13 CRITICAL)	Associations non assimilables à des vulnérabilités exploitables ou CVE uniques ; le second scan a remplacé le JSON complet par un export HIGH/CRITICAL ; version/date des bases à conserver
Qualification CVE, code et binaire	Cinq résultats étudiés : quatre écartés dans le périmètre observé, CVE-2022-23806 encore à vérifier	Qualification limitée à ces cinq résultats ; les autres associations ne sont pas toutes analysées

L'image analysée est identifiée par

sha256:a68f43720ea6ff331fa4b92becced20af14b72f4c3a22ca1f764076a8e42e1a5, avec
RepoDigest filebrowser/

filebrowser@sha256:1595cf9b36528113a18178996d9ff9ee8bc7814699bb5f8e1d8ad8ec48aa89ac. Trivy relève Alpine 3.13.4 avec E0SL=true et Go 1.16.2. La date de création Docker est le 6 avril 2021 ; le diagnostic de fin de support repose sur les preuves du J3, pas sur cette seule date.

2. Principaux constats et ordre de traitement

Confirmé qualifie l'état ou le défaut décrit, sans affirmer qu'une attaque a été reproduite. P1 désigne la première séquence de préparation, P2 un traitement haut mais conditionnel, P3 un traitement planifié ou une investigation à exposition limitée. Les scores CVSS historiques restent consultables dans les fiches J1 ; ils ne déterminent pas cet ordre.

Constats	Preuves déterminantes	Risque et priorité finale
C07 — Maintenance hôte	Pro non rattaché, plusieurs écarts de versions, candidats locaux identiques	P1 décision : choisir une voie de maintenance avant les correctifs ; disponibilité actuelle et fraîcheur APT à vérifier

Constats	Preuves déterminantes	Risque et priorité finale
C03/C04 — SSH logiciel et accès	Version locale et avis J1 ; port 22 joint ; mot de passe et transferts autorisés, root par clé possible	P1 préparation : point d'administration joignable ; distinguer conditions CVE et usages légitimes avant changement
C12 — Image hors support	ImageID précis, Alpine EOSL, composants Go anciens et résultats Trivy qualifiés	P1 préparation de migration : chaîne applicative non maintenue au contact des documents ; priorité structurelle, aucune compromission ni applicabilité de toutes les CVE affirmée
C10 — UID 0 et données RW	PID 1 UID/GID 0, montage RW, permissions observées	P2 investigation puis réduction : limiter les conséquences d'une compromission ; droits effectifs et compatibilité à tester
C01/C02 — containerd et Docker/BuildKit	Versions confirmées, avis GB, services/sockets présents	P2 : risque moteur conditionnel ; inventorier fonctions et constructions, puis traiter avec la maintenance hôte
C08 — Audit ciblé absent	Paquets et unité auditd absents ; journald/rsyslog actifs	P2 préparation : mieux reconstruire les actions sensibles ; dimensionner règles, volume et rétention
C05 — MAC SSH	Deux MAC 64 bits proposés à distance et dans sshd -T	P2 planification : retirer les algorithmes signalés après test des clients, dans le lot SSH
C06 — CUPS	Version ancienne, localhost, aucune imprimante, permissions confirmées	P3 : réduire une surface locale sans besoin établi ; dépendances à vérifier avant désactivation
C09 — Paramètres noyau	Valeurs sysctl et fragments relevés	P3 investigation : contexte réseau incomplet ; une modification globale pourrait casser Docker
C11 — Arrêts volontaires / reprise	Déclaration utilisateur et journaux d'arrêt concordants	Non pertinent comme panne ; P3 besoin d'exploitation pour la reprise automatique éventuelle

C12 complète la priorisation antérieure qui portait sur C01–C11. Son rang est justifié par le rôle applicatif et le cycle de maintenance, pas par les 13 lignes critiques seules. Si l'accès Internet est démontré, les accès SSH/HTTP et la migration applicative doivent être réexaminés en première séquence.

3. Plan de remédiation regroupé pour le J4

Les lots regroupent les changements qui traitent plusieurs constats. Les investigations préalables restent explicites. Les versions cibles ne sont pas inventées : elles seront choisies et vérifiées avant l'intervention.

Lot / constats	Action proposée	Priorité	Effet attendu	Impact ou contrainte possible	Vérification après modification
R01 — C07, C01, C02, C03 ; C06 si conservé	Décider accès aux correctifs applicables ou migration Ubuntu ; choisir les versions corrigées, sauvegarder l'état, mettre à jour l'hôte et les moteurs dans une fenêtre prévue	P1 préparation ; correctifs moteurs P2	Restaurer une voie de maintenance et réduire les écarts logiciels confirmés	Coût/éligibilité, compatibilité, redémarrages et interruption Docker/SSH ; ne pas faire une migration non testée sur les données seules	Versions exactes et source des paquets ; services actifs ; nouvelle connexion SSH ; conteneur et HTTP ; nouveau GB et LY de périmètre comparable ; reprise après redémarrage si concernée

Lot / constats	Action proposée	Priorité	Effet attendu	Impact ou contrainte possible	Vérification après modification
R02 — C03/C04/ C05	Coordonner correctif SSH et durcissement : PermitRootLogin no, MaxAuthTries 3, transferts TCP/agent et X11 no, LogLevel VERBOSE ; préparer liste MAC sans les deux umac-64 ; mot de passe à traiter séparément après validation des clés	P1 préparation pour accès, MAC P2	Réduire connexion root directe, fonctions de rebond et offre cryptographique faible ; améliorer traces	Tunnels et clients incompatibles ; perte d'administration possible ; ordre des fragments/Match à vérifier	sshd -t et configuration effective par contexte ; connexion administrateur et gvm-audit par clé ; refus des transferts/root attendus ; négociation MAC ; journaux et scan GB
R03 — C12, avec C10	Choisir une image File Browser maintenue identifiée par digest, préparer migration de la base/configuration/ données en environnement de test ; rescanner avant bascule ; tester UID non privilégié et droits minimaux	P1 préparation migration, restrictions C10 P2	Remplacer la chaîne hors support et réduire les conséquences d'un défaut applicatif	Format de base, options et permissions pouvant changer ; interruption et retour arrière après écritures à prévoir	Trivy sur l'image cible exacte avec bases datées ; examiner résultats résiduels ; version/processus/ montages ; connexion, téléchargement et téléversement de fichiers fictifs ; séparation des rôles et intégrité des données
R04 — C10	Après tests, limiter UID, capacités, privilèges supplémentaires et écritures aux chemins utiles ; étudier no-new-privileges et racine en lecture seule avec chemins d'écriture adaptés	P2, coordonné avec R03	Limiter droits et surface d'écriture du processus	L'application et sa base doivent pouvoir écrire aux emplacements requis ; un durcissement aveugle peut empêcher le démarrage	UID réel, capacités et NoNewPrivs ; fichiers nécessaires accessibles ; opérations non autorisées refusées ; tests fonctionnels et redémarrage ; aucune modification globale de propriétaire des documents sans justification
R05 — C08	Préparer auditd avec règles ciblées pour identité et configuration SSH ; dimensionner rotation/rétention et collecte future	P2	Traces structurées des actions sensibles	Bruit, espace disque, CPU et doublons ; chemins à valider	Règles chargées, événements de test retrouvés, rotation et stockage ; fonctionnement SSH/ Docker conservé ; intégration Wazuh seulement si mise en œuvre

Lot / constats	Action proposée	Priorité	Effet attendu	Impact ou contrainte possible	Vérification après modification
R06 — C06	Valider absence de dépendances ; désactiver cups.service, cups.socket, cups.path ; si conservé, correctif et permissions à examiner	P3	Réduire une fonction locale inutile	Impression ou applications desktop dépendantes interrompues	États des unités, absence de listener/socket attendu, application métier et dépendances vérifiées ; ne pas confondre arrêt du service et correction du paquet
R07 — C09	Qualifier interfaces, core_pattern, besoins Docker et origine/persistance ; appliquer seulement les sysctl retenus	P3 investigation , modification conditionnelle	Réduire un risque précis sans casser le réseau	Forwarding Docker, routage asymétrique et diagnostics impactés	Valeurs effectives et après redémarrage ; flux conteneur/hôte et accès SSH ; tests de refus correspondant au risque identifié
R08 — C11	Définir besoin de reprise ; si service attendu au démarrage, choisir et documenter une politique adaptée	P3 conditionnelle	Disponibilité conforme au besoin validé	Un redémarrage automatique peut remettre en écoute un service volontairement arrêté	Démarrage VM contrôlé, état/health du conteneur, HTTP et parcours applicatif ; comportement après arrêt volontaire et retour à l'état prévu

4. Investigations avant de choisir ou appliquer une mesure

Question ouverte	Décision qu'elle conditionne	Preuve attendue
Exposition externe et filtrage	Urgence des lots SSH et applicatif ; restriction des flux éventuelle	Règles effectives, routage et test autorisé depuis le point pertinent
Versions corrigées disponibles et cible maintenue	R01/R03	Avis et sources de paquets/image vérifiés, versions et plateforme compatibles, résultat de scan conservé
BuildKit et fonctions containerd utilisées	Applicabilité et ordre C01/C02	Constructions, utilisateurs, contextes et configurations réellement utilisés
Données, base File Browser et UID/mappage	R03/R04	Inventaire privé, sauvegarde restaurable, test migration et permissions avec données fictives
Dépendances SSH et CUPS	R02/R06	Liste des usages, clients, clés et applications à préserver
CVE-2022-23806	Qualification du risque spécifique dans C12	Chemin d'appel vers CurveParams.IsOnCurve et entrée contrôlable ; la migration structurelle n'exige pas d'affirmer cette CVE exploitable
Rétention et volume des événements	R05	Configuration et historique, capacité disque, simulation limitée de règles

Question ouverte	Décision qu'elle conditionne	Preuve attendue
Rapport LY et bases TR	Reproductibilité des comparaisons	Métadonnées, empreintes, versions/bases et options manquantes complétées

5. Décisions de non-intervention dans le périmètre actuel

Élément	Décision et justification	Condition de réexamen
Arrêts File Browser	Pas de traitement d'incident : arrêts volontaires expliqués	Arrêt inattendu nouveau ou exigence de reprise validée
CVE-2020-26160, CVE-2021-44716, CVE-2021-3711, CVE-2022-37434	Pas de correction spécifique fondée sur ces scénarios : exclus pour le périmètre qualifié dans la feuille CVE	Changement de code, protocole, bibliothèques ou chemin d'usage ; cette exclusion ne dispense pas R03
CUPS exposé à distance / absence totale de logs	Ne pas traiter ces scénarios non observés ; C06 et C08 restent retenus pour leurs défauts propres	Nouvelle écoute externe ou interruption de la collecte
Forwarding IPv4	Pas de désactivation globale sur la seule suggestion Lynis	Analyse réseau démontrant une valeur alternative compatible
Reconstruction pour exécuter Lynis interne	Ne pas transformer l'image en système complet uniquement pour l'outil	Méthode légère compatible identifiée ; aucune absence de scan assimilée à une absence de risque
Mot de passe SSH et permissions du socket CUPS	Pas de modification immédiate sans usages/critères établis	Clés administrateurs validées et besoin métier établi ; permissions service documentées

6. Préparer la mise en œuvre et le retour arrière

Pour chaque lot, renseigner au J4 le responsable réel, la fenêtre, les objets exactement modifiés et les critères d'arrêt. Archiver les versions et configurations initiales en privé. Vérifier une sauvegarde restaurable de la base/configuration et des données avant R03 ; conserver l'ancienne image par son identité. Un simple retour à l'ancien tag ne restaure pas une base migrée ou les documents modifiés : prévoir un état cohérent et contrôler les écritures pendant la bascule.

Pour SSH, garder console et session de secours jusqu'à validation d'une nouvelle connexion. Pour les règles audit/sysctl, restaurer uniquement les fichiers et valeurs du lot concerné ; ne pas purger globalement des règles ou traces. Éviter de cumuler tous les lots avant vérification : attribuer chaque effet au changement qui l'a produit.

Critère de clôture d'un lot : preuve avant/après sur le défaut ciblé, validation fonctionnelle, risque résiduel explicite et résultat du retour arrière ou de sa préparation. Un score amélioré seul ne ferme pas le constat.

7. Preuves et livrables finaux

Le dossier de preuves doit relier chaque constat aux rapports originaux et chaque action à ses validations. Conserver rapports GB A/B, rapport et journal LY, export d'image et empreintes, rapport TR avec options/bases, qualifications CVE et contrôles manuels datés. Les fichiers bruts restent privés ; masquer secrets,

identifiants et données internes dans les copies diffusées.

Source détaillée	Usage pour ce rapport
Greenbone J1	Versions, avis, QoD, couverture et scores historiques
Vérifications J2	Valeurs effectives, permissions, journalisation et arrêts expliqués
Image et conteneur	Identité de l'image, montages et limites de couverture
Scan Trivy	Inventaire et analyse reproductible de l'image
Qualification CVE	Scénarios exclus et condition encore ouverte
Consolidation finale	Registre unique des constats et exclusions

Livrables documentaires produits : synthèse du système et des méthodes, constats prioritaires, huit lots de remédiation, investigations et décisions de non-intervention. **Mise en œuvre prévue à partir du J4**, avec preuves de validation à compléter ; aucun changement n'est annoncé comme réalisé.

8. Preuves complémentaires à produire

Preuve manquante dans les huit captures	Contrôle à effectuer	Utilité
Détail Greenbone des constats G01 à G05	Ouvrir chaque résultat retenu : nom du test, composant/version, QoD, sévérité et solution ; exporter A/B avec les filtres notés	Étayer les écarts de paquets et les MAC SSH au-delà de la synthèse
Réussite de l'authentification Greenbone B	Ouvrir le résultat de connexion/authentification SSH et les contrôles locaux associés	Distinguer identifiant configuré et authentification réussie
Identité et date du rapport Lynis	Sur la VM : <code>date -Is, hostnamectl, lynis --version</code> , dates et empreintes du rapport/journal conservés	Relier l'audit à la cible ; la capture de synthèse seule ne donne pas la date d'exécution
Versions et maintenance de l'hôte	<code>dpkg-query -W containerd docker.io openssh-server cups cups-daemon et pro status</code>	Corroborer C01/C02/C03/C06/C07 sans utiliser seulement une bannière
SSH effectif	<code>sudo sshd -t</code> puis <code>sudo sshd -T</code> ; vérifier les contextes Match si présents	Étayer C04/C05 ; ne pas afficher de clé privée
Service CUPS et journalisation	États des unités CUPS, <code>sudo ss -lntup</code> , paquets auditd/rsyslog et états des services	Confirmer écoute locale et couverture de journalisation
Identité, UID et montages du conteneur	Inspection Docker ciblée et <code>/proc/1/status</code> selon le nom réel du conteneur, sans afficher les variables d'environnement	Étayer C10 et relier l'archive scannée à l'image réellement déployée
Rapport Trivy complet et liste des résultats	Produire un nouveau JSON complet sous un nouveau nom, conserver sa date et son empreinte ; extraire séparément HIGH/CRITICAL	Éviter l'écrasement et rendre les vulnérabilités visibles

Preuve manquante dans les huit captures	Contrôle à effectuer	Utilité
Validation d'une correction	Nouveau contrôle du défaut et test fonctionnel après une modification réellement effectuée	Clore le constat concerné ; aucune validation après correction n'est fournie ici

Ces contrôles complètent la preuve ; ils ne nécessitent pas de recréer toute l'infrastructure. Archiver les anciens rapports avant une relance. Les responsables et échéances restent à renseigner : aucune responsabilité ni date d'intervention n'est inventée.

9. Captures intégrées et légendes

GB-01 — Cible Greenbone avec identifiant SSH

AIS-Ubuntu20-avec-auth	192.168.122.229	1	All IANA assigned TCP	SSH:AIS-SSH-gvm-audit	   
Hosts Included 192.168.122.229 Maximum Number of Hosts 1 Allow simultaneous scanning via multiple IPs Yes Reverse Lookup Only No Reverse Lookup Unify No Alive Test Scan Config Default Port List All IANA assigned TCP Credentials SSH AIS-SSH-gvm-audit on Port 22					

Lecture : La cible AIS-Ubuntu20-avec-auth vise 192.168.122.229, un seul hôte, avec la liste All IANA assigned TCP et l'identifiant AIS-SSH-gvm-audit sur le port 22. Cela prouve la configuration visible, pas la réussite de l'authentification.

GB-02 — Cible Greenbone sans authentification

AIS-Ubuntu20-sans-auth	192.168.122.229	1	All IANA assigned TCP		   
Hosts Included 192.168.122.229 Maximum Number of Hosts 1 Allow simultaneous scanning via multiple IPs Yes Reverse Lookup Only No Reverse Lookup Unify No Alive Test Scan Config Default Port List All IANA assigned TCP Apply to page contents    					

Lecture : La cible AIS-Ubuntu20-sans-auth vise la même adresse et la même liste de ports. Aucun identifiant SSH n'apparaît dans cette vue.

GB-03 — Rapport Greenbone B terminé

 **Report:** **AM** Done

Coordinated Universal Time ID: aeb90e4a-b789-4ef3-ab1b-7fd7afcae1ee Created: Wed, Sep 30, 2026 10:13 AM Coordinated Universal Time Modified: Wed, Sep 30, 2026 10:29 AM Coordinated Universal Time Owner: admin

Information	Results (200 of 387)	Hosts (1 of 1)	Ports (2 of 3)	Applications (22 of 22)	Operating Systems (1 of 1)	CVEs (2122 of 2122)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
-------------	-------------------------	-------------------	-------------------	----------------------------	-------------------------------	------------------------	-------------------------	------------------------------	----------------------------	------------------

Task Name **AIS-B-Full-and-fast-SSH**

Scan Time Wed, Sep 30, 2026 10:13 AM Coordinated Universal Time-Wed, Sep 30, 2026 10:29 AM Coordinated Universal Time

Scan Duration 0:16 h

Scan Status Done

Hosts scanned 1

Filter apply_overrides=0 levels=chml min_qod=70 result_hosts_only=0

Timezone Coordinated Universal Time (UTC)

Lecture : Tâche AIS-B-Full-and-fast-SSH, état Done, un hôte scanné, du 30 septembre 10:13 à 10:29 UTC, soit 12:13 à 12:29 à Paris. Les compteurs et le filtre sont visibles ; le détail des constats ne l'est pas.

GB-04 — Rapport Greenbone A terminé

 **Report:** **AM** Done

Coordinated Universal Time ID: d9692337-64e4-450e-8659-c123aeb5c9c1 Created: Wed, Sep 30, 2026 10:02 AM Coordinated Universal Time Modified: Wed, Sep 30, 2026 10:17 AM Coordinated Universal Time Owner: admin

Information	Results (3 of 33)	Hosts (1 of 1)	Ports (1 of 2)	Applications (2 of 2)	Operating Systems (1 of 1)	CVEs (1 of 1)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
-------------	----------------------	-------------------	-------------------	--------------------------	-------------------------------	------------------	-------------------------	------------------------------	----------------------------	------------------

Task Name **A192.168.122.229**

Scan Time Wed, Sep 30, 2026 10:02 AM Coordinated Universal Time-Wed, Sep 30, 2026 10:17 AM Coordinated Universal Time

Scan Duration 0:15 h

Scan Status Done

Hosts scanned 1

Filter apply_overrides=0 levels=chml min_qod=70 result_hosts_only=0

Timezone Coordinated Universal Time (UTC)

Lecture : Tâche A192.168.122.229, état Done, un hôte scanné, du 30 septembre 10:02 à 10:17 UTC, soit 12:02 à 12:17 à Paris. La couverture et la profondeur diffèrent du scan B ; les compteurs ne sont pas des vulnérabilités uniques confirmées.

LY-01 — Synthèse Lynis

```
=====

Lynis security scan details:

Hardening index : 57 [##### ]
Tests performed : 221
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Lynis Modules:
- Compliance Status [?]
- Security Audit [V]
- Vulnerability Scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

Lecture : Indice de durcissement 57, 221 tests et un plugin. Les chemins /var/log/lynis.log et /var/log/lynis-

report.dat sont indiqués. L'indice n'est ni un pourcentage de sécurité ni une preuve de conformité.

LY-02 — Avertissements et suggestions Lynis

```
oliv@ubuntu-oliv:~$ sudo grep -E "(warning|suggestion|)[\]= " /var/log/lynis-report.dat
warning[|=UNWS]Version of Lynis is very old and should be updated.|-|
suggestion[|=CUST-0280]Install libpam-trpdir to set STMP and STMPDIR for PAM sessions.|-|
suggestion[|=CUST-0285]Install libpam-usb to enable multi-factor authentication for PAM sessions.|-|
suggestion[|=CUST-0810]Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|
suggestion[|=CUST-0811]Install apt-listchanges to display any significant changes prior to any upgrade via APT.|-|
suggestion[|=CUST-0830]Install debian-goodies so that you can run checkrestart after upgrades to determine which services are using old versions of libraries and need restarting.|-|
suggestion[|=CUST-0831]Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are using old versions of libraries and need restarting.|-|
suggestion[|=CUST-0870]Install debsecan to generate lists of vulnerabilities which affect this installation.|-|
suggestion[|=CUST-0875]Install debsums for the verification of installed package files against MD5 checksums.|-|
suggestion[|=DEB-0080]Install fail2ban to automatically ban hosts that commit multiple authentication errors.|-|
suggestion[|=B00T-5122]Set a password on GRUB bootloader to prevent altering boot configuration (e.g. boot in single user mode without password).|-|
suggestion[|=B00T-5260]Protect rescue.service by using sulogin.|-|
suggestion[|=KRNL-5780]determine why /vmlinuz is missing on this Debian/Ubuntu system. [/vmlinuz]-|
suggestion[|=KRNL-5780]Check the output of apt-cache policy manually to determine why output is empty.|-|
suggestion[|=AUTH-9262]Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc.|-|
suggestion[|=AUTH-9286]Configure minimum password age in /etc/login.defs.|-|
suggestion[|=AUTH-9286]Configure maximum password age in /etc/login.defs.|-|
warning[|=AUTH-9308]No password set for single user mode.|-|
suggestion[|=AUTH-9308]Set password for single user mode to minimize physical access attack surface.|-|
suggestion[|=AUTH-9320]Default umask in /etc/login.defs could be more strict like 027.|-|
suggestion[|=FILE-6310]To decrease the impact of a full /home file system, place /home on a separated partition.|-|
suggestion[|=FILE-6310]To decrease the impact of a full /tmp file system, place /tmp on a separated partition.|-|
suggestion[|=FILE-6310]To decrease the impact of a full /var file system, place /var on a separated partition.|-|
suggestion[|=STOR-1840]Disable drivers like USB storage when not used, to prevent unauthorized storage or data theft.|-|
suggestion[|=NAME-4028]Check DNS configuration for the dns domain name.|-|
suggestion[|=PKGS-7370]Install debsums utility for the verification of packages with known good database.|-|
suggestion[|=PKGS-7394]Install package apt-show-versions for patch management purposes.|-|
suggestion[|=NETW-2704]Check connection to this nameserver and make sure no outbound DNS queries are blocked (port 53 UDP and TCP).|-|
warning[|=NETW-2704]Nameserver 127.0.0.53 does not respond.|-|
warning[|=NETW-2705]Couldn't find 2 responsive nameservers.|-|
suggestion[|=NETW-3032]Consider running ARP monitoring software (arpwatch, arpon).|-|
suggestion[|=PRINT-2307]Access to CUPS configuration could be more strict.|-|
suggestion[|=FIRE-4513]Check iptables rules to see which rules are currently not used.|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[AllowAgentForwarding (YES --> NO)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[ClientAliveCountMax (3 --> 2)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[Compression (YES --> (DELAYED)NO)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[LogLevel (INFO --> VERBOSE)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[MaxAuthTries (6 --> 2)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[MaxSessions (10 --> 2)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[PermitRootLogin (WITHOUT-PASSWORD --> NO)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[Port (22 --> )].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[TCPKeepAlive (YES --> NO)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[X11Forwarding (YES --> NO)].|-|
suggestion[|=SSH-7408]consider hardening SSH configuration[AllowAgentForwarding (YES --> NO)].|-|
suggestion[|=LOGG-2190]check what deleted files are still in use and why.|-|
suggestion[|=BANN-7120]Add a legal banner to /etc/issue, to warn unauthorized users.|-|
suggestion[|=BANN-7130]Add legal banner to /etc/issue.net, to warn unauthorized users.|-|
suggestion[|=ACCT-9622]Enable process accounting.|-|
suggestion[|=ACCT-9626]Enable sysstat to collect accounting (no results).|-|
suggestion[|=ACCT-9628]Enable auditd to collect audit information.|-|
suggestion[|=CONT-8180]Test output of both 'docker ps -a' and 'docker info', to determine why they report a different amount of containers.|-|
suggestion[|=FINT-4391]Install a file integrity tool to monitor changes to critical and sensitive files.|-|
suggestion[|=TOOL-5002]Determine if automation tools are present for system management.|-|
suggestion[|=KRNL-6000]One or more sysctl values differ from the scan profile and could be tweaked.[Change sysctl value or disable test (skip-test=KRNL-6000:<sysctl-key>)]
suggestion[|=IRON-7230]Harden the system by installing at least one malware scanner, to perform periodic file system scans.[Install a tool like rkhunter, chkrootkit, OSSEC]
```

Lecture : Extraction du rapport : outil ancien, mode single-user, DNS, SSH-7408, auditd, CUPS et sysctl notamment. Ce sont des résultats à contextualiser. L'alerte DNS ne prouve pas seule une panne actuelle ; les suggestions noyau ne doivent pas être appliquées globalement à un hôte Docker.

TR-01 — Scan Trivy complet sur archive

```
oliv@ubuntu-oliv:~$ TRIVY_WORK_DIR="$HOME/Documents/entreprise/AIS/Modules/preuves-trivy-filebrowser"
IMAGE_ARCHIVE="$TRIVY_WORK_DIR/filebrowser-v2.15.0-image.tar"
REPORT_JSON="$TRIVY_WORK_DIR/trivy-filebrowser-v2.15.0.json"

date -Is
trivy image \
  --input "$IMAGE_ARCHIVE" \
  --scanners vuln \
  --list-all-pkgs \
  --format json \
  --output "$REPORT_JSON"
TRIVY_EXIT=$?
echo "Code retour Trivy=$TRIVY_EXIT"
sha256sum "$REPORT_JSON"
2026-10-01T15:46:12+02:00
2026-10-01T15:46:12+02:00      INFO      [vuln] vulnerability scanning is enabled
2026-10-01T15:46:12+02:00      INFO      Detected OS      family="alpine" version="3.13.4"
2026-10-01T15:46:12+02:00      INFO      [alpine] Detecting vulnerabilities...      os_version="3.13" repository="3.13" pkg_num=20
2026-10-01T15:46:12+02:00      INFO      Number of language-specific files      num=1
2026-10-01T15:46:12+02:00      INFO      [gobinary] Detecting vulnerabilities...
2026-10-01T15:46:12+02:00      WARN      Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.74/guide/scanner/vulnerability#severity-selection for details.
2026-10-01T15:46:12+02:00      WARN      This OS version is no longer supported by the distribution      family="alpine" version="3.13.4"
2026-10-01T15:46:12+02:00      WARN      The vulnerability detection may be insufficient because security updates are not provided
Code retour Trivy=0
e7e6db0925387558665338b14542402e35de06c77fc6abd91cf358ec0ef965 /home/oliv/Documents/entreprise/AIS/Modules/preuves-trivy-filebrowser-v2.15.0.json
```

Lecture : Exécution le 1er octobre à 15:46:12 +02:00 avec --input, --scanners vuln, --list-all-pkgs et sortie JSON. Alpine 3.13.4, 20 paquets et l'avertissement de fin de support sont visibles. Code retour 0 et empreinte de cet export affichés ; aucune liste de CVE n'apparaît dans la capture.

TR-02 — Scan Trivy filtré et conversion

```
oliv@ubuntu-oliv:~$ trivy image --input "$IMAGE_ARCHIVE" --scanners vuln --list-all-pkgs --format json --output "$REPORT_JSON" --severity HIGH,CRITICAL
2026-10-01T15:47:10+02:00      INFO      [vuln] vulnerability scanning is enabled
2026-10-01T15:47:10+02:00      INFO      Detected OS      family="alpine" version="3.13.4"
2026-10-01T15:47:10+02:00      INFO      [alpine] Detecting vulnerabilities...      os_version="3.13" repository="3.13" pkg_num=20
2026-10-01T15:47:10+02:00      INFO      Number of language-specific files      num=1
2026-10-01T15:47:10+02:00      INFO      [gobinary] Detecting vulnerabilities...
2026-10-01T15:47:10+02:00      WARN      Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.74/guide/scanner/vulnerability#severity-selection for details.
2026-10-01T15:47:10+02:00      WARN      This OS version is no longer supported by the distribution      family="alpine" version="3.13.4"
2026-10-01T15:47:10+02:00      WARN      The vulnerability detection may be insufficient because security updates are not provided
oliv@ubuntu-oliv:~$ trivy convert \
  --format table \
  --output "$TRIVY_WORK_DIR/trivy-filebrowser-v2.15.0.txt" \
  "$REPORT_JSON"
sha256sum "$TRIVY_WORK_DIR/trivy-filebrowser-v2.15.0.txt"
2026-10-01T15:47:16+02:00      WARN      [report] No enabled scanners found. Summary table will not be displayed.
737742a1e4636a82d643bf5ab544a0e9ace3a2942482465b0813795904f2e /home/oliv/Documents/entreprise/AIS/Modules/preuves-trivy-filebrowser/trivy-filebrowser-v2.15.0.txt
```

Lecture : Nouvelle exécution à 15:47:10 avec --severity HIGH,CRITICAL vers le même JSON, puis conversion en table. Le JSON précédent est remplacé. La capture montre un avertissement de conversion et une empreinte du fichier texte, mais pas le tableau des CVE ; le contenu et les compteurs sont établis par lecture du JSON disponible.

10. Conclusion

L'analyse croise une vue distante Greenbone, un audit local Lynis, un inventaire de l'image Trivy et les contrôles manuels consignés dans le dossier. Les risques les plus prioritaires concernent la maintenance de l'hôte, l'administration SSH et la migration de la chaîne applicative ancienne. Les moteurs de conteneurs, les droits sur les documents et la traçabilité suivent selon leurs conditions d'accès. CUPS et les paramètres noyau font l'objet d'un traitement planifié ou d'investigations ciblées.

Les huit captures prouvent l'exécution ou les synthèses visibles, mais ne couvrent pas tous les constats détaillés. Le rapport distingue donc les résultats documentés, les preuves directement examinées et les compléments attendus. Aucun incident, accès Internet, exploitation réussie ou correctif appliqué n'est déduit de ces seuls résultats.